

שי מרדכי <shaimordehai@gmail.com>



דיווח מס' 11265

messages 18

4 באוגוסט 2025 בשעה 9:30

דיווחי פגיעויות <cve@cyber.gov.il>
<shaimordehai@gmail.com> "To: "shaimordehai@gmail.com
Cc: דיווחי פגיעויות <cve@cyber.gov.il>

שי שלום,

קיבלנו את דיווחך הנ"ל.

מבקש לוודא, האם מדובר במוצר שזה האתר שלו?

[/https://www.sbcl.org](https://www.sbcl.org)

כמו כן, האם תוכל לשלוח דיווח מפורט באנגלית? אני רוצה שיפלו טעויות בדיווח אם אתרגם בעצמי.

אפשר קובץ PDF לכתובת מייל זו.

בברכה,

שמעון

4 באוגוסט 2025 בשעה 17:36

דיווחי פגיעויות <cve@cyber.gov.il>
To: דיווחי פגיעויות <cve@cyber.gov.il>, <shaimordehai@gmail.com> "shaimordehai@gmail.com", <shaimordehai@gmail.com>

שי שלום,

ממתין לתשובתך.

[Quoted text hidden]

10 באוגוסט 2025 בשעה 12:59

דיווחי פגיעויות <cve@cyber.gov.il>
To: דיווחי פגיעויות <cve@cyber.gov.il>, <shaimordehai@gmail.com> "shaimordehai@gmail.com", <shaimordehai@gmail.com>

שי שלום,

עדיין ממתין לתשובתך.

בברכה,

שמעון

[Quoted text hidden]

19 באוגוסט 2025 בשעה 14:15

דיווחי פגיעויות <cve@cyber.gov.il>
To: דיווחי פגיעויות <cve@cyber.gov.il>, "shaimordehai@gmail.com" <shaimordehai@gmail.com>

שי שלום,

נא התייחסותך לפנייתנו.

[Quoted text hidden]

26 באוגוסט 2025 בשעה 16:06

דיווחי פגיעויות <cve@cyber.gov.il>
To: דיווחי פגיעויות <cve@cyber.gov.il>, "shaimordehai@gmail.com" <shaimordehai@gmail.com>

שי שלום,

נוצר קשר ראשוני עם היצרן.

מבקש שתשיב לפנייתי לגבי תרגום תיאור הפגיעות לאנגלית.

איני מומחה ל-LISP ואני מנסה להימנע מתרגום הדיווח בעצמי, שעלול להיות לא מדויק.

אפשר לשלוח אליי כקובץ PDF לכתובת זו.

בברכה,

שמעון

26 באוגוסט 2025 בשעה 16:46

שי מרדכי <shaimordehai@gmail.com>
To: דיווחי פגיעויות <cve@cyber.gov.il>

שלום,
סליחה על חוסר הזמינות. אני תוך כדי מילואים, מבחנים, מעבר דירה...
אנסה לשבת על זה שוב ולשלוח הכל מפורט באנגלית.

[Quoted text hidden]

26 באוגוסט 2025 בשעה 17:41

דיווחי פגיעויות <cve@cyber.gov.il>
To: שי מרדכי <shaimordehai@gmail.com>, דיווחי פגיעויות <cve@cyber.gov.il>

שי שלום,

תודה שחזרת אליי.

אמתין שתשלח לי את פירוט הפגיעות באנגלית.

בברכה,

שמעון

<From: שי מרדכי <shaimordehai@gmail.com>
Sent: Tuesday, August 26, 2025 4:47 PM
<To: דיווחי פגיעויות <cve@cyber.gov.il>

[Quoted text hidden]

[Quoted text hidden]

שימו לב, דואר אלקטרוני זה מקורו מחוץ לרשת הארגון. יש לוודא כי הנכם מכירים את השולח וכי התוכן בטוח. אחרת, אנא הימנעו מלחיצה על קישורים או קבצים מצורפים.

7 בספטמבר 2025 בשעה 14:01

<cve@cyber.gov.il> **דיווחי פגיעויות**
To: דיווחי פגיעויות <cve@cyber.gov.il>, שי מרדכי <shaimordehai@gmail.com>

שי שלום,

אני רוצה להעביר התרגום ליצרן. האם תוכל לשלוח לי בקרוב?

בברכה,

שמעון

<From: דיווחי פגיעויות <cve@cyber.gov.il>
Sent: Tuesday, August 26, 2025 5:42 PM
<To: שי מרדכי" <shaimordehai@gmail.com>; דיווחי פגיעויות <cve@cyber.gov.il>
Subject: RE: דיווח מס' 11265

שי שלום,

[Quoted text hidden]

14 בספטמבר 2025 בשעה 10:47

<cve@cyber.gov.il> **דיווחי פגיעויות**
To: דיווחי פגיעויות <cve@cyber.gov.il>, שי מרדכי <shaimordehai@gmail.com>

שי שלום,

ממתין לתשובתך.

[Quoted text hidden]

17 בדצמבר 2025 בשעה 13:14

<shaimordehai@gmail.com> **שי מרדכי**
To: דיווחי פגיעויות <cve@cyber.gov.il>

Subject: Vulnerability Report: Lexical Scope Bypass via Dynamic Binding Injection in SBCL 2.3.2

1. Researcher Information

- **Name:** Shay Mordechai
- **Role:** Junior Security Researcher
- **GitHub:** <https://github.com/shay-mordechai>
- **LinkedIn:** [linkedin.com/in/shay-mor](https://www.linkedin.com/in/shay-mor)

2. Vulnerability Overview

- **Target:** SBCL (Steel Bank Common Lisp) Compiler
- **Official Website:** <https://www.sbcl.org/>
- **Vulnerability Type:** Logical Flaw / Scope Isolation Bypass
- **Impact:** Integrity violation, sensitive data exposure, and potential bypass of security-critical lexical isolation
- **Status:** Proof-of-Concept (PoC) Verified

3. Summary of Findings

During security research involving semantic fuzzing and binary analysis of the SBCL compiler, I identified a critical logical flaw in the handling of variable bindings. The vulnerability allows an attacker to use a specifically crafted macro containing a `proclaim` statement to transform a protected lexical variable into a dynamic one during execution. This effectively bypasses the lexical isolation (scoping) guaranteed by the `let` construct, allowing a global override of supposedly local, private data.

4. Proof of Concept (PoC)

The following code demonstrates how a lexical variable `secret-data`, which should be protected from external modification, is compromised:

Lisp

```
;; Vulnerable Macro: Forces a symbol to become dynamic (special)
(defmacro isolation-bypass-attack (target new-value)
  `(progn
    (proclaim '(special ,target)) ; Injecting dynamic binding
    (setf ,target ,new-value))) ; Overriding the lexical value

(defun verify-vulnerability ()
  (let ((secret-data "PROTECTED_DATA"))
    (format t "Before Attack: ~A~%" secret-data)

    ;; Triggering the bypass
    (isolation-bypass-attack secret-data "COMPROMISED")

    (format t "After Attack: ~A~%" secret-data)
    (if (string= secret-data "COMPROMISED")
        (format t "[!] VULNERABILITY CONFIRMED: Lexical isolation bypassed.~%")
        (format t "[+] Isolation preserved.~%")))))

(verify-vulnerability)
```

5. Technical Analysis

The root cause appears to be a lack of validation in the `proclaim` function regarding active lexical environments. When `(proclaim '(special ...))` is called, the compiler updates the symbol's flags globally. If this symbol is currently bound lexically,

SBCL fails to maintain the separation, leading the runtime to resolve the symbol via the dynamic environment instead of the lexical one.

Binary analysis via IDA Pro indicates that the SPECIAL flag in the symbol structure is modified without checking if it shadows an existing lexical binding in the current lexenv. This represents a fundamental design flaw in the interplay between the proclaim mechanism and lexical environment isolation.

6. Impact Assessment

- **Integrity:** High. Critical variables used in security-sensitive logic (e.g., sandbox flags, authentication tokens) can be manipulated.
- **Confidentiality:** Medium. Private lexical data can be forced into the dynamic scope, making it accessible to unintended functions.

7. Recommended Mitigation

Implement a check within the proclaim and declaim mechanisms to prevent changing the binding type of a symbol if it is already active within a lexical scope, or ensure that existing lexical bindings remain shadowed and unaffected by the global flag change.

בתאריך יום א', 14 בספט' 2025 ב-7:47 מאת דיווחי פגיעויות <cve@cyber.gov.il>:
[Quoted text hidden]

22 בדצמבר 2025 בשעה 17:08

שי מרדכי <shaimordehai@gmail.com>
To: דיווחי פגיעויות <cve@cyber.gov.il>

בקשה להקצאת CVE וקרדיט עבור דיווח - חולשה ב-SBCL

שלום רב,

בהמשך לדיווח שלי על חולשת האבטחה ב-SBCL Compiler, ברצוני לוודא את הסטטוס מול הספק.

מאחר שמדובר בממצא משמעותי, אבקש לדעת:

1. האם שוריין מספר CVE (CVE ID) עבור החולשה? במידה ולא, אשמח אם תוכלו להקצות אחד כ-CNA, או שאפנה ל-MITRE-ישירות.

2. אבקש לוודא כי בפרסום ה-Advisory הרשמי (וברישומי ה-CVE), הקרדיט על הממצא יופיע תחת שמי: Shay Mordechai.

אודה לעדכוןכם כדי שאוכל להיערך לפרסום מסודר (Responsible Disclosure) לאחר הוצאת התיקון.

בברכה, שי מרדכי

בתאריך יום ד', 17 בדצמ' 2025 ב-11:14 מאת שי מרדכי <shaimordehai@gmail.com>:
[Quoted text hidden]

8 בפברואר 2026 בשעה 20:20

שי מרדכי <shaimordehai@gmail.com>
To: דיווחי פגיעויות <cve@cyber.gov.il>

היי שמעון,

בהמשך לבקשתך לקבלת הפירוט הטכני באנגלית, ומכיוון שחלף זמן, הגשתי השבוע (13/01/26) את הדיווחים ישירות ל-MITRE כדי לקדם את הקצאת ה-CVEs.

מצורף העתק של טופס ההגשה המלא (PDF) שנשלח ל-MITRE. מסמך זה מכיל את התיאורים הטכניים המדויקים באנגלית (Vulnerability Description, Attack Vector, Impact) עבור שלושת הממצאים (Stack Exhaustion, Memory Corruption, Isolation) בדיוק כפי שביקשת. (Bypass)

אשמח אם תוכלו להשתמש במידע זה כדי לקדם את הטיפול מול היצרן (SBCL) ולעדכן אותי אם בכוונתכם לפעול כ-CNA במקביל.

בברכה, שי מרדכי

בתאריך יום ב', 22 בדצמ' 2025 ב-17:08 מאת שי מרדכי <shaimordehai@gmail.com>:
[Quoted text hidden]

CVE - Common Vulnerabilities and Exposures (CVE).pdf 
284K

9 בפברואר 2026 בשעה 12:32

דיווחי פגיעויות <cve@cyber.gov.il>
To: שי מרדכי <shaimordehai@gmail.com>, דיווחי פגיעויות <cve@cyber.gov.il>

שי שלום,

אם הבנתי נכון קידמת רישום ה-CVE מול MITRE, אבל הם לא מעדכנים את היצרן?

[Quoted text hidden]

9 בפברואר 2026 בשעה 19:12

שי מרדכי <shaimordehai@gmail.com>
To: דיווחי פגיעויות <cve@cyber.gov.il>

היי שמעון,
נכון בדיוק, אשמח שתעבירו אתם ליצרן, ובנתיים רישום ה-CVE מטופל ע"י MITRE.
אשמח שתעבירו אתם ליצרן את הפירוט הטכני (מה-PDF) כדי שיקדמו את התיקון

בתאריך יום ב', 9 בפבר' 2026 ב-12:32 מאת דיווחי פגיעויות <cve@cyber.gov.il>:
[Quoted text hidden]

4 במרץ 2026 בשעה 0:58

שי מרדכי <shaimordehai@gmail.com>
To: דיווחי פגיעויות <cve@cyber.gov.il>

היי שמעון,
רציתי לבדוק האם יש התקדמות בסטטוס הפנייה שלי (דיווח מס' 11265) מול היצרן (SBCL)?
במקביל, אני ממשיך את המעקב מול MITRE לגבי הקצאת מספרי ה-CVE.
אשמח לעדכון כשיתאפשר.

תודה רבה,
שי מרדכי



בתאריך יום ב', 9 בפבר' 2026 ב-19:12 מאת שי מרדכי <shaimordehai@gmail.com>:
[Quoted text hidden]

2 באפריל 2026 בשעה 22:10

שי מרדכי <shaimordehai@gmail.com>
To: דיווחי פגיעויות <cve@cyber.gov.il>

היי שמעון,
עבר למעלה מחודש מהפנייה האחרונה שלי וקרוב ל-4 חודשים מאז הדיווח המפורט באנגלית.
מאחר וחלפו מעל 90 יום, כמקובל, אני מתכנן לפרסם write-up של הממצאים בעוד כשבועיים. אשמח לדעת עד אז אם היצרן אישר
את קבלת המידע ואם יש התקדמות בתיקון, כדי שאוכל לעדכן את הפרסום בהתאם.

תודה רבה ומועדים לשמחה,
שי מרדכי

בתאריך יום ג', 3 במרץ 2026 ב-22:58 מאת שי מרדכי <shaimordehai@gmail.com>:

5 באפריל 2026 בשעה 12:38

דיווחי פגיעויות <cve@cyber.gov.il>
To: שי מרדכי <shaimordehai@gmail.com>, דיווחי פגיעויות <cve@cyber.gov.il>

שי שלום,

בזמן לחימה אנו מתעדפים פעילויות אחרות (בעיקר התרעות וצמצום חשיפות) על פני טיפול ב-CVE.

מאחר ובחרת לפנות ל-MITRE ישירות לקבלת הקצאת מספרי CVE, איננו יכולים לטפל בפרסום הפגיעויות וטיפולנו יתמצה בהעברת המידע ליצרן.

אעדכן כשתהיה לי אינדיקציה מהם שהמידע בידיהם, ובתקווה גם מטופל.

כארגון ממלכתי שמטרתו היא שיפור הגנת הסייבר במרחב הישראלי, אנו מתעדפים טיפול היצרן בפגיעות על פני פרסום הפגיעות לאחר 90 יום או מעט יותר, בפרט אם הפגיעות טרם טופלה.

לעניות דעתי מומלץ להמתין עם הפרסום עד לקבלת אישור מהיצרן שהפגיעות טופלה, אך כמובן הדבר נתון לשיקולך.

[Quoted text hidden]

25 במאי 2026 בשעה 14:16

שי מרדכי <shaimordehai@gmail.com>
To: דיווחי פגיעויות <cve@cyber.gov.il>

לצוות CERT-IL היקר,
שלום רב,

אני פונה אליכם כדי לעדכן על מחקר אבטחה שסיימתי בנושא Internals של קומפיילר ה-SBCL ביולי 2025. המחקר עסק בניחוח ארכיטקטוני, מנגנוני ניהול זיכרון ותהליכי תרגום פקודות, אשר הובילו לזיהוי מספר מקרי קצה המאפשרים יצירת קוד מכונה לא תקין.

ברצוני לציין כי פעלתי בהתאם למדיניות ה-Responsible Disclosure: **במהלך תשעת החודשים האחרונים** ניסיתי ליצור קשר עם הגורמים האחראים לדיווח, וכן עם מפתחי הפרויקט ישירות - בנוגע לממצאים, אך לצערי לא התקבלה כל תגובה. לאור העובדה שתקופת ההמתנה הסתיימה ללא מענה, ובמטרה להעלות את המודעות בקרב הקהילה לסיכונים אלו, החלטתי לפרסם את המחקר ואת המתודולוגיה בשקיפות מלאה.

ניתן לעיין במחקר ובממצאי הניסוי בקישור הבא:
<https://github.com/shay-mordechai/sbcl-compiler-research>
אני משתף אתכם במידע זה כחלק מהתנהלות אחראית. אשמח לעמוד לרשותכם לכל שאלה מקצועית או הבהרה בנוגע לממצאים.

בברכה,
שי מרדכי

חוקר אבטחה

<https://www.linkedin.com/in/shay-mordechai>

בתאריך יום א', 5 באפר' 2026 ב-12:38 מאת דיווחי פגיעויות <cve@cyber.gov.il>:

[Quoted text hidden]